

POURQUOI CE GUIDE

Votre TPE est une cible. Voici pourquoi.

Les cybercriminels ne ciblent pas seulement les grandes entreprises. Ils ciblent les systèmes mal protégés — et les TPE françaises sont parmi les plus vulnérables. Pas parce que vous êtes moins intelligents, mais parce que vous avez moins de moyens pour vous défendre, et que personne ne vous a encore dit où regarder.

Ce guide résume les 5 erreurs que je retrouve dans **9 TPE sur 10** lors de mes audits. Ce sont des failles simples, souvent corrigées en quelques heures — mais qui, non corrigées, peuvent coûter des dizaines de milliers d'euros.

60%

des PME victimes d'un
ransomware déposent le bilan
dans les 18 mois

18 000€

coût moyen d'une cyberattaque
pour une TPE française

1/5

TPE attaquée chaque année en
France

Sources : ANSSI, Rapport sur la menace informatique 2024 — Hiscox, Cyber Readiness Report 2024.

Dans les pages suivantes, je vous présente ces 5 failles une par une : ce que c'est, pourquoi c'est dangereux, et ce que vous pouvez faire immédiatement pour vous protéger.

FAILLE N°1

Le mot de passe qui ouvre tout

La faille la plus simple — et la plus exploitée. En moins de 2 minutes, un attaquant peut accéder à votre messagerie, votre comptabilité ou vos fichiers clients.

Ce qui se passe vraiment

Les hackers utilisent des attaques dites "par dictionnaire" ou "par force brute". Ils testent automatiquement des milliers de combinaisons à la seconde. Un mot de passe comme **"Societe2023!"** — que beaucoup croient sûr — est cassé en moins de 3 heures.

Pire : si vous utilisez le même mot de passe sur plusieurs services (messagerie, banque, cloud), une seule fuite suffit à tout compromettre. En 2024, plus de 8 milliards d'identifiants ont circulé sur le dark web.

Les signaux d'alerte chez vous

- Vous utilisez le prénom d'un proche ou le nom de votre entreprise
- Votre mot de passe fait moins de 12 caractères
- Vous utilisez le même mot de passe sur plusieurs sites
- Vos collaborateurs partagent des identifiants communs
- Vous ne changez jamais vos mots de passe

CE QUE VOUS POUVEZ FAIRE CETTE SEMAINE

1. Installez un gestionnaire de mots de passe (Bitwarden gratuit, ou 1Password). Il génère et mémorise des mots de passe complexes uniques pour chaque service.
2. Activez l'authentification à deux facteurs (2FA) sur votre messagerie et votre espace bancaire. Même si votre mot de passe est volé, l'accès reste bloqué.
3. Vérifiez si vos identifiants ont fuité : rendez-vous sur **haveibeenpwned.com** et entrez vos adresses email professionnelles.

FAILLE N°2**Les mises à jour que personne ne fait**

80% des cyberattaques exploitent des failles connues depuis des mois — et pour lesquelles des correctifs existent. Si vous ne les appliquez pas, votre système est une porte ouverte.

Pourquoi c'est critique

Quand un éditeur publie une mise à jour de sécurité, il révèle en même temps la faille qui vient d'être corrigée. Les hackers s'empressent alors d'exploiter cette faille sur tous les systèmes qui n'ont pas encore été mis à jour.

Le délai entre la publication d'un correctif et son exploitation massive est en moyenne de **15 jours**. Si vous attendez "le bon moment" pour faire vos mises à jour, vous êtes exposé pendant ces 15 jours.

Les systèmes les plus souvent négligés dans les TPE : routeur WiFi (souvent jamais mis à jour), NAS de sauvegarde, logiciels de comptabilité, et téléphones professionnels sous Android.

Action immédiate

- Activez les mises à jour automatiques sur tous les postes Windows/Mac
- Vérifiez la date du dernier firmware de votre routeur WiFi professionnel
- Mettez à jour votre antivirus et vérifiez qu'il est actif sur tous les postes
- Planifiez une heure par mois pour vérifier les mises à jour des logiciels métier

FAILLE N°3

La sauvegarde qui ne sauve rien

Vous avez une sauvegarde. Mais dans 60% des cas, elle est inutilisable le jour où vous en avez vraiment besoin — parce qu'elle est incomplète, corrompue, ou chiffrée par le même ransomware qui a attaqué votre réseau.

Le cas réel qui se répète

Un cabinet comptable de Normandie. 12 salariés. Une sauvegarde quotidienne sur un disque externe connecté au serveur. En apparence, tout est en ordre.

Un jour, un ransomware chiffre tous les fichiers du serveur. La sauvegarde aussi — parce qu'elle était connectée au même réseau. **3 semaines d'arrêt complet. 34 000€ de pertes directes. Des clients partis.**

La règle d'or : la sauvegarde doit être **déconnectée** du système principal. Et vous devez la tester régulièrement en essayant de restaurer un fichier réel.

LA RÈGLE 3-2-1

3 copies de vos données — **2** supports différents — **1** copie hors site (cloud ou site distant).

Exemple concret : fichiers sur votre serveur + sauvegarde sur disque externe déconnecté + sauvegarde automatique sur cloud chiffré (ex: Backblaze, 7€/mois).

FAILLE N°4**L'email qui ressemble au vrai**

Le phishing est responsable de 91% des cyberattaques. Un email convaincant suffit pour qu'un collaborateur clique sur un lien, entre ses identifiants, ou valide un virement frauduleux.

Les 3 techniques les plus utilisées

Le phishing classique : un email imitant votre banque, votre fournisseur ou un prestataire vous demande de "valider votre compte". Le lien redirige vers un faux site qui vole vos identifiants.

Le spear phishing : l'attaquant a fait des recherches sur vous (LinkedIn, site web). L'email cite votre nom, votre client, un projet en cours. Il semble légitime. C'est le plus dangereux.

La fraude au virement (FOVI) : quelqu'un se fait passer pour votre dirigeant ou un fournisseur et demande un virement urgent sur un nouveau compte. Cette fraude coûte des millions chaque année aux TPE françaises.

Comment reconnaître un email suspect

- L'expéditeur est inconnu ou l'adresse ne correspond pas au domaine officiel
- L'objet crée une urgence ("Action requise", "Votre compte va être bloqué")
- On vous demande de cliquer sur un lien pour "confirmer" quelque chose
- Le lien dans l'email ne correspond pas au domaine réel (survolez avant de cliquer)
- On vous demande un virement ou un paiement inhabituels, même de la part de votre dirigeant

Règle d'or : tout virement ou changement de coordonnées bancaires doit être confirmé par téléphone au numéro habituel — jamais au numéro indiqué dans l'email.

FAILLE N°5

Le smartphone qui trahit tout

Vos collaborateurs accèdent à leurs emails professionnels, vos fichiers et vos outils depuis leurs téléphones personnels. Sans aucune politique de sécurité. C'est une faille ouverte sur votre système entier.

Le problème concret

Un téléphone personnel, c'est aussi : des applications tierces non contrôlées, une connexion WiFi publique parfois utilisée, une mise à jour de l'OS souvent repoussée, et aucun effacement à distance possible si le téléphone est perdu.

Si ce téléphone accède à votre messagerie professionnelle ou à votre Google Drive partagé, une application malveillante installée par votre collaborateur peut exfiltrer vos données sans que vous le sachiez.

Sur le plan juridique (RGPD), vous restez responsable des données clients traitées — même depuis un téléphone personnel. En cas de fuite, c'est votre entreprise qui répond devant la CNIL.

Ce qu'il faut mettre en place

- Politique BYOD ("Bring Your Own Device") claire : règles d'usage des téléphones perso
- Accès aux emails pro via un client dédié avec authentification 2FA obligatoire
- Séparation des données pro et perso (application MDM ou conteneur sécurisé)
- Procédure de désactivation immédiate en cas de vol ou perte du téléphone
- Formation de 30 minutes pour sensibiliser les équipes aux risques mobiles

CHECKLIST D'URGENCE FLGB

12 actions à réaliser cette semaine

Ces 12 actions ne nécessitent aucun budget particulier et peuvent être réalisées par n'importe quel dirigeant de TPE. Elles réduisent votre exposition immédiatement.

MOTS DE PASSE

- Installer un gestionnaire de mots de passe (Bitwarden, gratuit)
- Changer les mots de passe des comptes critiques (messagerie, banque, cloud)
- Activer la double authentification (2FA) sur la messagerie pro

SAUVEGARDES

- Vérifier que votre sauvegarde existe et est récente (moins de 24h)
- Tester la restauration d'un fichier depuis votre sauvegarde
- Déconnecter le support de sauvegarde du réseau principal

MISES À JOUR

- Activer les mises à jour automatiques sur tous les postes
- Vérifier le firmware de votre routeur WiFi professionnel
- S'assurer que l'antivirus est actif sur tous les postes

ORGANISATION

- Former les collaborateurs à reconnaître un email de phishing (30 min)
- Établir une règle : tout virement inhabituel = vérification téléphonique
- Définir qui peut accéder à quelles données (principe du moindre privilège)

Vous avez compté vos failles ?

Si vous en avez identifié 3 ou plus, votre TPE est exposée à un risque sérieux. Ce guide vous donne le diagnostic. Le Kit Clé en Main vous donne le traitement.

KIT CLÉ EN MAIN CYBERSÉCURITÉ TPE — 997€ HT

Audit · Plan d'action · Politique de sécurité · Formation équipe · Suivi 30 jours

En 5 jours, votre TPE passe d'exposée à protégée.

<https://louisguybriar-c.github.io/flgb-conseils/kit-cyber.html>

contact@flgb-conseils.fr · François Briar, FLGB Conseils

Ce guide est confidentiel et destiné à son destinataire. Reproduction partielle autorisée avec mention de la source : FLGB Conseils — François Briar. Les statistiques citées proviennent de rapports publics ANSSI et Hiscox 2024.